Access Control Procedure - OT Environment

1. Purpose

This procedure defines how access to OT systems and assets is granted, managed, and revoked to ensure only authorized users and systems can access the operational technology (OT) environment, in alignment with IEC 62443-3-3 (SR 1.1 - Human User Identification and Authentication, SR 1.2 - User Authorization, SR 1.3 - Account Management).

2. Scope

Applies to all users (internal staff, contractors, and vendors) accessing the plant's OT systems, including:

- SCADA systems
- PLCs, HMIs, and RTUs
- Engineering workstations
- OT network infrastructure
- Remote access tools

3. Roles and Responsibilities

OT Security Manager: Overall procedure owner and reviewer
OT System Administrators: Implementation of access controls
Plant Operations Manager: Approval of access for operators
HR / Contractor Manager: Notifying access changes (onboarding/offboarding)
Users: Adhering to approved access levels and policies

4. Procedure

4.1 User Authentication
- All users must have unique credentials (no shared accounts allowed, except with formal exception and auditing).
- Passwords must follow complexity requirements: Minimum 12 characters, with upper-case, lower-case, number, and symbol.
- Multifactor authentication (MFA) must be used where technically feasible.

4.2 User Authorization
- Access is granted based on least privilege and role-based access control (RBAC):
  - Operator: View and control assigned processes
  - Engineer: Modify logic/programming of assigned assets
  - Administrator: Full configuration rights
- Access requests must be approved by the relevant line manager and OT Security Manager.

4.3 Account Management
- Provisioning: New accounts created only after completion of access request form and approvals.
- De-provisioning: Accounts must be disabled within 24 hours of role change or departure.
- Review: User access must be reviewed quarterly.
- Vendor accounts: Time-bound and activity-scoped access only.

4.4 Service Accounts
- Must be explicitly approved and documented.
- Used only by processes or devices; not for human interaction.
- Passwords stored securely and rotated regularly.

4.5 Logging and Auditing
- All successful and failed login attempts must be logged.
- Audit logs must be stored securely for a minimum of 12 months.
- Regular review of access logs by OT Security Manager (at least monthly).

5. Enforcement

Violations of this procedure may result in disciplinary action, including revocation of access, and must be reported to the OT Security Manager and plant management.

6. References

- IEC 62443-2-1: Security Program Requirements for IACS Asset Owners
- IEC 62443-3-3: System Security Requirements and Security Levels
- [Company] Information Security Policy